

RBAC Architecture Overview

Role-Based Access Control (RBAC) is a security mechanism that restricts system access based on assigned user roles. It ensures that users only have permissions that match their responsibilities.

Core Concepts:

- Users: Individuals accessing the system.
- Roles: Collections of permissions assigned to users.
- Permissions: Allowed actions within the system.
- Resources: Protected APIs, pages, or data objects.

Architecture Layers:

1. Authentication (Identity Provider, JWT, OAuth2)
2. Authorization Middleware (Policy Evaluation)
3. Resource Gatekeeping (API/Controller Enforcement)

RBAC Benefits:

- Least privilege access
- Centralized permission management
- Reduced security risks
- Compliance support (ISO, SOC2)

Use Cases:

- Web applications enforcing admin/user roles
- API systems with fine-grained permissions
- Multi-team enterprise platforms